

Portfolio Project: Cyber Pharmacy

ISO/IEC 27001:2022 Control Mapping

and Statement of Applicability (extract)

Prepared by: Haley Thava

Date: 2026

Disclaimer:

This report is a fictional cybersecurity assessment produced as an academic portfolio project. Cyber Pharmacy is a fictional organisation. The software products mentioned are either fictional or to provide operational realism. Services referenced are to provide operational realism. No actual assessments of any software products or services were made. All findings and identified gaps are related solely to the fictional pharmacy. This entire assessment is fictional, and all the findings in this report are fictional.

ISO/IEC 27001:2022 is published by ISO and IEC. The Clauses and Annex A control numbers and titles used here are drawn from the standard and paraphrased for this academic portfolio project. None of the standard's text has been reproduced. This project is not affiliated with or endorsed by ISO or IEC. The published standard should be consulted for the official wording.

Understanding ISO/IEC 27001:2022

Management system clauses and Annex A controls

Management system clauses

Clauses 4 to 10 are the mandatory management system requirements if an organisation wants to be ISO/IEC 27001 certified.

- Clause 4 - context of the organisation
 - Covers understanding internal and external issues, interested parties and the defined scope of the Information Security Management System (ISMS)
- Clause 5 - Leadership
 - Covers management commitments, information security policy and assigned roles
- Clause 6 - Planning
 - Covers risk assessment, risk treatment and information security objectives
- Clause 7 - Support
 - Covers resource, competence, awareness, communication and documented information
- Clause 8 - Operation
 - Covers implementing risk treatment through security controls
- Clause 9 - Performance evaluation
 - Covers monitoring, internal audit and management reviews
- Clause 10 - Improvement
 - Covers corrective actions and continual improvement

Annex A

Annex A is a set of 93 controls that an organisation can choose from to treat its identified risks. The controls are grouped into 4 themes:

- Organisational - policies, processes, roles and supplier management
- People - staff awareness, training and responsibilities
- Physical - securing premises, equipment and physical access
- Technological - access control, monitoring and backups

Annex A controls are not mandatory, and should be selected based on a risk assessment. These choices will then be recorded in the SoA.

Statement of Applicability (SoA)

The SoA is a document that connects the clauses with the Annex A controls. Clause 6.1.3 requires the organisation to produce an SoA that lists and justifies the necessary controls.

This extract reproduces the SoA for a defined subset of controls. It demonstrates how the risks identified in the NIST SP 800-30 risk assessment conducted on Cyber Pharmacy translate into ISO/IEC 27001:2022 Annex A control selections, applicability decisions and implementation status judgement.

Scope

Following Clause 4.3, the scope of this portfolio project is Cyber Pharmacy: a single-site, privately owned community pharmacy in Perth, Western Australia. The pharmacy has 16 staff, providing dispensing, non-sterile compounding, dose administration aids, vaccination, over the counter medicines, and retail services. The information assets in scope are the pharmacy's holdings of patient health and identity data, employee records and the systems that process them. This includes: the cloud hosted A-Dispense dispensing software and point of sale software, national digital health integrations (eRx, Active Script List, My Health Record, PBS Online, and the Australian Immunisation Register), the shared email account and the supporting network and endpoint environment managed by an external Managed Service Provider (MSP).

Consistent with Clause 6.1.3, control selection is risk led. Meaning rather than addressing all 93 Annex A controls, it selects one principal control for each of the eight priority risks (R1 to R8) identified in Cyber Pharmacy's cybersecurity maturity and risk assessment, using NIST SP 800-30. A full SoA is keyed to every applicable Annex A control rather than to risks. This compact version ensures the eight selected controls together address all eight identified risks. This scoping reflects the reality of a small fictional single-site pharmacy, where appropriate ISMS concentrates on the controls that treat the selected risks.

Methodology

Control numbers and titles are referenced from ISO/IEC 27001:2022 Annex A, with each control name paraphrased. Each selected control is linked to the risk and to the corresponding NIST CSF 2.0 subcategories, preserving traceability with the main portfolio project. Implementation status is recorded on a three point qualitative scale:

- Met - the control is fully implemented and operating as intended.
- Partial - some capabilities exist, but it is incomplete.
- Gap - the control is absent.

These status judgments are based on the current state findings documented in the Cybersecurity Maturity and Risk Assessment of Cyber Pharmacy.

Statement of Applicability (SoA)

Annex A	Control Name	Applicability	Risk ID	Status	Justification (current state)	NIST CSF 2.0
A.5.19	Managing information security in vendor relationships.	Yes	R4	Gap	The MSP and vendors were onboarded with no security assessment. The MSP holds remote desktop admin access to every workstation, and no contract defines security, monitoring, or breach notification obligations. A compromise at the MSP would compromise all PII before the pharmacy became aware.	GV.OC-02, ID.AM-02, ID.AM-04
A.5.24	Incident management planning and preparedness.	Yes	R3	Gap	No incident response plan, runbooks, or escalation paths exist. NDB and My Health Records Act notification pathways are not operationalised, so the statutory 30-day assessment window cannot realistically be met. The gap is preparedness and awareness.	GV.OC-01, GV.OC-03, GV.RR-02, RS.MA-01
A.5.30	ICT preparedness to support business continuity.	Yes	R8	Gap	The pharmacy relies solely on cloud hosted A-Dispense with no confirmed backup SLA, no defined RTO or RPO, and no tested restoration. The paper fallback sustains only short outages. A prolonged outage halts dispensing, PBS claiming and other operational processes.	ID.AM-04, PR.DS-11, RS.MA-01, RC.RP-03
A.8.3	Restricting access to information.	Yes	R7	Gap	A-Dispense applies no role based restriction, so a dispensary assistant has the same access to clinical data as a pharmacist and a compromised low-privilege account reaches the same data as a privileged one. Curiosity driven or malicious insider access is both undetectable and unpreventable.	PR.AA-05, DE.CM-01
A.8.5	Implementing secure authentication.	Yes	R1	Gap	A single shared email account serves 16 staff with no MFA, passwords are reused and written on sticky notes and remote access uses a shared MSP login. The shared mailbox is the most plausible initial access point for full compromise, and MFA is the single most valuable control.	PR.AA-01, PR.AA-05

A.8.13	Backups of information and systems.	Yes	R2	Gap	Backups rely on implicit vendor trust with no confirmed SLA. The back office PC holding compounding scans is not backed up at all, and a full system restore has never been tested. In a ransomware event the pharmacy could not confidently recover. Restoring unverified backups risks reintroducing malware or corrupted clinical data.	PR.AT-01, PR.DS-11, DE.CM-01, RS.MA-01, RC.RP-03
A.8.16	Monitoring for abnormal activity.	Yes	R6	Gap	There is no SIEM, log aggregation or network monitoring. Microsoft Defender runs unmanaged, and the A-Dispense audit trail is not reviewed. Unauthorised My Health Record access or upload from a compromised session would go undetected. Since the NDB clock starts at awareness, undetected compromise will likely result in financial consequences.	GV.OC-03, PR.AA-01, PR.AA-05, PR.AT-01, RS.MA-01
A.8.22	Network segregation.	Yes	R5	Gap	Dispensing workstations, POS terminals, CCTV, and staff personal phones share one flat, unfiltered segment. The CCTV covering the S8 safe runs default credentials, making it both a pivot point into clinical systems and a single point of failure for footage relied upon in S8 diversion and discrepancy investigations. Segregating embedded devices removes the pivot path and protects monitoring integrity.	ID.AM-01, ID.AM-03, DE.CM-01

Findings

All eight selected controls are currently assessed as gaps. This is consistent with the NIST CSF 2.0 Tier 1 (Partial) maturity, where controls are largely absent.

The same picture emerges from both frameworks (NIST CSF 2.0 and ISO/IEC 27001:2022). Both frameworks point to the same weakness: weak identity and access controls, no monitoring and no incident response readiness.

The highest value first steps are as follows:

- Enforce multi-factor authentication (MFA) and remove shared logins
 - This addresses A.8.5
- Enforce Role Based Access in A-Dispense
 - This addresses A.8.3
- Document an incident response plan covering NDB and MyHR Act notification
 - This addresses A.5.24
- Add security breach notification clause to the MSP contract
 - This addresses A.5.19
- Confirm and test backups
 - This addresses A.8.13
- Engage managed monitoring and continuity support through MSP
 - This addresses A.5.30 and A.8.16
- Segregate network using VLANs, especially for embedded devices
 - This addresses A.8.22

Limitations

This has been made deliberately compact. This extract selects one principal control per identified risk to keep this portfolio project concise. A full SoA is keyed to every applicable Annex A control and would record many more, including supporting controls.

This has been conducted as a point in time, qualitative judgment. Status ratings reflect the assessment of the fictional environment at a single point in time.

Paraphrased Annex A control names were used. The published standard should be consulted for authoritative wording.

As stated in the title page, Cyber Pharmacy and any software mentioned are fictional. Where real entities and software are named (e.g. PBS, MHR, AIR, Microsoft), they are only referenced for operational realism. No real organisation, vendor, company or individual has been assessed.

Sources

- ISO/IEC 27001:2022
- NIST SP 800-30 Rev.1
- NIST Cybersecurity Framework 2.0
- Cybersecurity Maturity and Risk Assessment Portfolio Project (Cyber Pharmacy)